

Final Report

Vulnerability Assessment & Penetration Testing

PREPARED FOR:

Isend Pte.Ltd.



PREPARED By:

Envision Tech Pvt. Ltd.



Oct 2025

Legal Disclaimer

This Vulnerability Assessment and Penetration Testing (VAPT) report is intended solely for the use of **Isend Pte. Ltd.**. Unauthorized access, distribution, modification or disclosure of this document, in whole or in part, without prior written consent from **Envision Tech Pvt. Ltd.**, is strictly prohibited.

The findings, observations and recommendations contained in this report are based on the information available and the scope of testing agreed upon at the time of the assessment. While every effort has been made to ensure accuracy and completeness, **Envision Tech Pvt. Ltd.** does not guarantee that all vulnerabilities have been identified.

The organization is solely responsible for implementing the recommended security measures and maintaining continuous security practices to safeguard its information assets.

Terms of Use

This report contains confidential information that is being provided to **Isend Pty. Ltd.** Extreme care should be exercised when handling, referring or copying this document. **Envision Tech** authorizes **Isend** to view or disseminate this document as they see fit in accordance with iSend's data handling policies.

In no event shall **Envision Tech** be liable for the incidental, collateral or consequential damages that occur out of the use of this information.

Document Version and Change Control

SN.	Version	Prepared By	Reviewed By	Approved By	Remarks
1	0.1 Draft	Envision Tech Pvt. Ltd	Pitambar Sah	Prateek S. Kharel	
2	0.1 Final	Pitambar Sah	Prateek S. Kharel	Pawan Kumar Sharma	

List of Acronyms and Abbreviations

CSP	Content Security Policy
CVE	Common Vulnerabilities Exposures
DNS	Domain Name System
DoS	Denial Of Service
EOL	End Of Life
HTTP	Hyper Text Transfer Protocol
HTTPS	Hyper Text Transfer Secure
IS	Information Security
IT	Information Technology
MITM	Man In The Middle
OS	Operating System
OWASP	Open Web Application Security Project
POC	Proof Of Concept
RCE	Remote Code Execution
SSL	Secure Socket Layer
VAPT	Vulnerability Assessment and Penetration Testing

TABLE OF CONTENT

1. INTRODUCTION	6
1.1 Acknowledgement	6
2. BACKGROUND	7
2.1 Objective	7
2.2 Scope	7
2.3 Control	7
2.4 Methodology	8
2.5 Test Limitations	12
3. EXECUTIVE SUMMARY	13
3.1 Brief Overview	13
3.2 Summary Of Findings	18
3.3 Summary Of Recommendations	19
4. DISCOVERED VULNERABILITIES	20
4.1 Clickjacking	20
4.2 TLS v1.0 and TLS v1.1 Depreciated Protocol Detection	21
4.3 Autocomplete Attribute Not Disabled on Form Fields	23
4.4 Missing Content Security Policy (CSP) Header	24
4.5 Multiple Outdated (Next.js React Framework)	26
4.6 CORS Misconfiguration	28
4.7 Use of vulnerable outdated components Axios v1.1.3	30
4.8 API Credentials Exposed	31
4.9 User Enumeration	33
4.10 End-of-Life Nginx (1.22.1)	35
5. CONCLUSION	37
6. APPENDIX	38
A.1 CVSSv3 Risk Rating	38
A.2 CWE (Common Weakness Enumeration)	38
A.3 OWASP TOP 10	38
A.4 NIST SP 800-115	39
A.5 Tools Used	40

1. INTRODUCTION

1.1 Acknowledgement

We are grateful and would like to express our sincere gratitude to Isend Pty. Ltd. for giving us the opportunity to conduct the Vulnerability Assessment and Penetration Testing.

We greatly appreciate the cooperation and support extended by all staff members throughout the engagement. The friendly environment and timely coordination facilitated the smooth and successful completion of the assessment. We extend our special thanks to the Management Team, HR Department, IT Department and all supporting Departments for their continuous technical assistance and provision of necessary documentation during the testing process. Their collaboration and expertise were instrumental in ensuring a comprehensive and effective security evaluation.

Lastly, we would like to thank the entire team for their trust, hospitality, and active involvement. Their commitment to security and openness to improvement made this engagement not only successful but also a valuable learning experience for our team.

2. BACKGROUND

2.1 Objective

The objective of this engagement was to evaluate the current state of the systems in the scope and to identify vulnerabilities in the internal and external systems that the client, users, internal users and external adversaries could exploit in the network of iSend. We also defined the following objectives:

- Evaluate IT related controls to ensure the security and reliability of the systems.
- Evaluate the security posture against organization standards.
- Detects known and unknown security weaknesses in application.
- Evaluate and rank vulnerabilities based on their severity, potential impact and likelihood of exploitation.
- Provide actionable recommendations to mitigate risks and improve the security framework.
- Demonstrate a commitment to security, reassuring clients, partners and regulatory bodies.

2.2 Scope

The systems and applications that are included in the scope of work are as follows:

Web Application	Url
Isend Web Application	https://isend.com.ng https://isendremit.com https://isendglobal.com https://www.isendbiz.com https://hub.isendremit.com/login

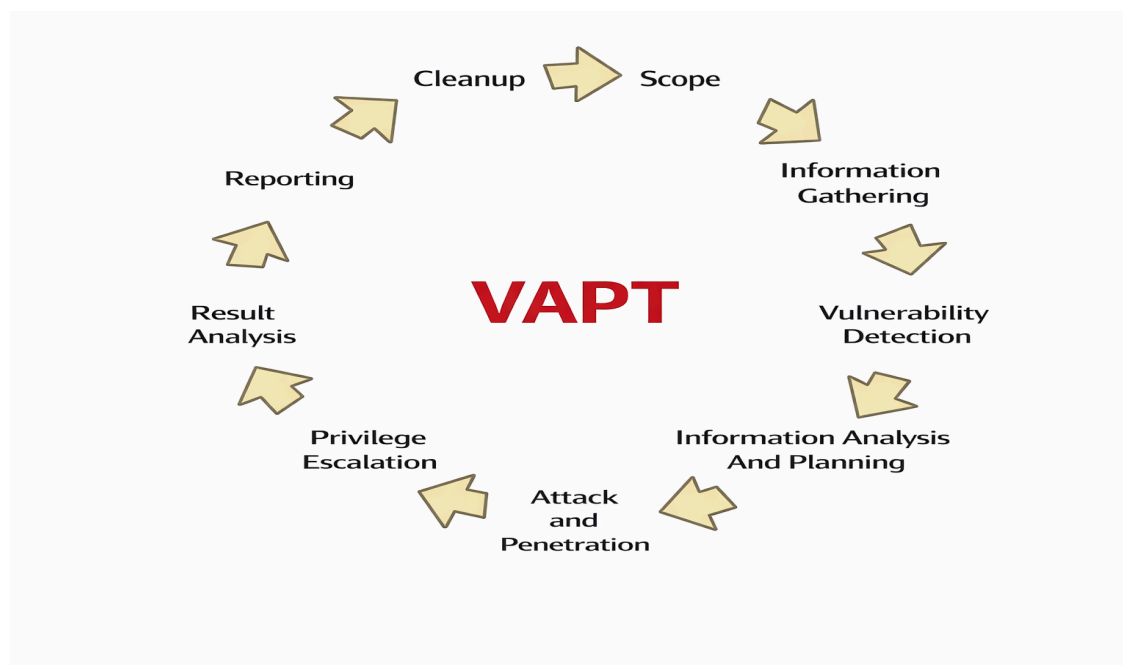
2.3 Control

The above scope were measured under following controls:

OWASP: Open web Application security Project is a globally recognized non-profit organization focused on improving the security of software. It provides tools, resources, and methodologies to help developers, organizations, and security professionals identify and mitigate vulnerabilities in web applications, APIs and other software systems.

2.4 Methodology

VAPT Methodology refers to the structured and systematic approach used to conduct Vulnerability Assessment and Penetration Testing. It outlines the step-by-step process to identify, assess and test vulnerabilities in a system, application, or network. The methodology ensures that the testing is comprehensive, repeatable and aligned with best practice.



Scope

The scope of VAPT defines the boundaries, assets and objectives of the security assessment. It determines what will be tested, how it will be tested and any limitations during the testing process. Establishing a clear scope is critical for ensuring that the VAPT engagement is focused, efficient, and aligned with the client's needs.

Information Gathering

Information gathering in VAPT refers to the process of collecting data and intelligence about the target system, network or application that is being assessed. This phase is also known as reconnaissance or foot printing. Basically we'll try to gain information about an organization's digital footprints, like their IP addresses, DNS records, mail server, sub domains, older snapshots of a web application, backend technologies, server information, publicly disclosed vulnerabilities in the software being used etc. Information gathering is divided into two key methods which are active reconnaissance and passive reconnaissance. Both approaches aim to collect data about the target system, network or application but differ in their techniques and potential to alert the target.

- **Active Reconnaissance:** Active reconnaissance involves direct interaction with the target system or network. The goal is to probe the target to gather specific information, such as open ports, running services, and system configurations. Techniques used to perform Active Reconnaissance are Port Scanning, Service Fingerprinting, Network Scanning, Web Application Scanning and Vulnerability Scanning.
- **Passive Reconnaissance:** Passive reconnaissance involves collecting information about the target without directly interacting with it. The goal is to gather as much data as possible without alerting the target to the reconnaissance activity. It can be done by Gathering domain registration details, Identifying domain names, subdomains, and associated records Reviewing online databases, news articles, and other freely available information.

Vulnerability Detection: Vulnerability detection is the process of identifying weaknesses, flaws, or misconfigurations in systems, networks or applications that attackers could exploit. The purpose of Vulnerability Detection is to identify security gaps and provide actionable insights for remediation, before attackers exploit them. Below is an overview of vulnerability detection and its techniques performed during VAPT:

-
- **Automated Scanning:** Automated tools scan systems and networks to identify known vulnerabilities based on pre-configured rules or databases. Tools used for automated scanning are Nessus, OpenVAS, Nikto.
 - **Manual Testing:** Manually tests are performed in the system to identify vulnerabilities that automated tools might miss. It is done to detect logic flaws or business logic vulnerabilities, Testing authentication, authorization and session management.

Information Analysis and Planning

Information analysis and planning phase in vulnerability Assessment and Penetration Testing involves examining the data gathered during the reconnaissance stage and creating a structured plan for conducting the assessment. This phase is essential for ensuring that the testing process is efficient, targeted, and aligned with organizational objectives.

Key aspects of information analysis and planning :

- **Asset discovery:** Identifying all critical systems, applications, networks, and data within the target environment that need to be assessed.
- **Threat modeling:** Analyzing potential threats that could exploit vulnerabilities in the system based on its function, data sensitivity, and business impact.
- **Vulnerability identification:** Using tools and techniques to scan for known vulnerabilities in the system, including software flaws, misconfigurations, and outdated patches.
- **Risk assessment:** Evaluating the likelihood and potential impact of identified vulnerabilities to prioritize remediation efforts.
- **Scope definition:** Clearly outlining the boundaries of the VAPT engagement, including which systems, applications, and network segments will be tested.
- **Access management:** Obtaining necessary access credentials and permissions to conduct the assessment.
- **Methodology selection:** Choosing appropriate testing methodologies, such as black-box, grey-box, or white-box testing, depending on the level of information

available.

- **Communication plan:** Establishing clear communication channels with stakeholders to provide updates on the testing progress and findings.

Attacks and Penetrations

Attack and Penetration phase refers to the stage where we actively exploit identified vulnerabilities to gain unauthorized access to a system, essentially simulating a real-world attack to assess the severity of the discovered weaknesses, this phase typically follows the reconnaissance and vulnerability assessment stages and precedes the reporting phase. We also verify and evaluate each vulnerability found during the scanning phase to identify false positives and calculate the actual risk the vulnerability poses in the client's infrastructure

Key points about the attack and penetration phase:

- **Exploitation:** This is the core activity where we use the vulnerabilities found during the scanning and analysis phase to gain access to the system, potentially accessing sensitive data or executing malicious code.
- **Post-exploitation:** Once access is gained, we further explore the system to assess the potential impact of the breach, such as escalating privileges, moving laterally within the network, or exfiltrating data.

Privilege Escalation

Privilege Escalation refers to the process of gaining higher levels of access within a system or network than initially authorized. It is a critical step during the Attack and Penetration phase, as it simulates what an attacker could achieve after exploiting an initial vulnerability.

Reporting

After we identified the vulnerabilities and their exploitability, we calculated the risks they carry and relayed our findings to our clients. In this stage, we compiled a report and presented it to the client.

Cleanup

Cleanup phase is a critical final step that ensures the environment is restored to its original or better state after testing activities. This phase is important to prevent unintended security or operational risks resulting from the testing process.

2.5 Test Limitations

We sincerely hope that the auditee understands that it is impossible to test information systems for every potential security vulnerability. This report does not form a guarantee that your assets are secure from all kinds of threats.

In addition, the assessment is only restricted to the provided scope, therefore, Envision Tech Pvt. Ltd. does not bear any responsibility for the issues found in the assets not listed within the provided scope at the beginning of the project.

3. EXECUTIVE SUMMARY

iSend contracted with Envision Tech to perform the following security assessment task of Web Application Vulnerability Assessment and Penetration Testing.

The security engagement occurred during the period from <> to <>. By engaging Envision Tech, iSend clearly understands the need to protect its information and resources. This report documents the findings of a Web Application Vulnerability Assessment and Penetration Testing carried out by Envision Tech Pvt. Ltd. to evaluate the security posture of iSend and identify potential vulnerabilities that could be exploited by attackers. Also to provide the best recommendation for the known vulnerabilities discovered during the testing process. The test led to discovery of 10 vulnerabilities from low to critical. The severity includes clickjacking vulnerabilities where an attacker can frame a website which can lead an attacker to hijack user clicks for malicious intent.

3.1 Brief Overview

Envision Tech identified a total of 10 different types of vulnerabilities which range from Critical to informational levels in all accessed areas. The 10 vulnerabilities are Clickjacking, CORS, Missing CSP etc. The table below shows the list of vulnerabilities along with their impact found within the iSend Web Applications.

Vulnerability ID	Vulnerabilities	Impact
VULN-001	Clickjacking	Medium
VULN-002	TLSv1.0 and TLSv1.0	Medium
VULN-003	Autocomplete Attribute Not Disabled in Form	Low
VULN-004	Missing Content Security Policy (CSP) Header	Medium

VULN-005	Outdated (Next.js React Framework) 13.5.4	High
VULN-006	CORS Misconfiguration	High
VULN-007	Use of vulnerable outdated component	Medium
VULN-008	API Credential Exposed	High
VULN-009	User Enumeration	Low
VULN-010	End Of Life Nginx	High

Critical Risk Issues: 0

High Risk Issues: 4

Medium Risk Issues: 4

Low Risk Issues: 2

CVSS v3 Base Score Metrics

The following metrics were used to determine the impact of a vulnerability.

Exploitability Metrics		
Attack Vector (AV)	Network(N)	A vulnerability can be exploited from a public network/outside of an organization.
	Adjacent(A)	A vulnerability can be exploited only from the internal network of an organization.
	Local(L)	An attacker should have local/virtual access to exploit the vulnerability.
	Physical(P)	An attacker should have physical access to exploit the vulnerability.
	High(H)	An attack depends on conditions beyond the attacker's control. To carry out an exploit, an attacker should not

Attack Complexity (AC)		have any firewall/IDS/Network restrictions.
	Low(L)	An attack can be carried out without any condition. An attacker has easy access to vulnerable systems.
Privileges Required (PR)	None(N)	An attacker is unauthorized before the attack. An exploit can be carried out without any credentials.
	Low(L)	An attacker will need low-level privilege/credentials to exploit a vulnerable system.
	High(H)	An attacker will need high-level privileges/credentials to exploit a vulnerable system.
User Interaction (UI)	None(N)	A vulnerable system can be exploited without interaction from any user.
	Required(R)	An attacker needs a user to interact to carry out an attack. For example: Clicking a malicious link in an email, Downloading malicious files from the internet.
Scope(S)	Unchanged (U)	A vulnerability only affects the system in which it is exploited.
	Changed(C)	An exploited vulnerability affects another system along with the system which is exploited. For example, A vulnerability in a windows system leads to the compromise of a database that is hosted in another system/server.
Impact Metrics		
	None(N)	There is no loss of confidentiality from an exploit.
	Low(L)	Some loss of confidentiality. An attacker will have access to restricted information but will not have

Confidentiality(C)		any control over what information he obtains.
	High(H)	Total loss of confidentiality. An attacker will have access to all the restricted information about the affected system and its resources.

		In some cases, the attacker will have little/limited access to restricted information but that information disclosure may have a huge impact on an organization.
Integrity(I)	None(N)	Modification of data is not possible, which keeps integrity intact.
	Low(L)	Modification of data is possible but the attacker doesn't have control over the modification of what they want to achieve. The modification does not have a huge impact on the exploited component.
	High(L)	Complete loss of protection of data resulting in total loss of integrity. For example, an attacker can read/write/delete any file present in the exploited system. In some cases, the attacker will have few/limited modification privileges but those modifications may have a huge impact on an organization.
Availability(A)	None(N)	No impact on the availability of the affected system.
	Low(L)	Reduced performance or interruption of a resource. An attacker cannot completely interrupt or stop a service.
	High(H)	Total loss of availability. An attacker can fully deny access to a resource which results in the stoppage of a service.

The list of various of types of vulnerability founds are listed below:

Vulnerabilities	CVSSv3 Matrices	CVSSv3 Base Score	Severity	Internal/ External	Privilege Required
Clickjacking				External	None
TLSv1.0 and TLSv1.0				External	None
Autocomplete Attribute Not Disabled in Form				External	None
Missing Content Security Policy (CSP) Header				External	None
Outdated (Next.js React Framework) 13.5.4				External	None
CORS Misconfiguration				External	None
Use of vulnerable outdated component				External	None
API Credential Exposed				External	None
User Enumeration				External	None
Total					

3.2 Summary Of Findings

The Summary of the findings along with their impacts identified during the testing of iSendI Web Application are as follows:

1. The iSend web applications lack anti-framing protections, allowing attackers to perform clickjacking attacks that trick users into executing unintended actions.
2. The web applications support deprecated TLS protocol versions (1.0 and 1.1) that lack modern cryptographic protections.
3. Form fields allow browser autocomplete, potentially exposing previously entered data on shared or compromised devices.
4. The absence of a Content Security Policy increases the risk of client-side attacks such as script injection and data theft.
5. The application uses an outdated Next.js framework version with known security vulnerabilities.
6. The application reflects arbitrary origins in CORS headers while allowing credentials, enabling unauthorized cross-origin access to sensitive data.
7. The application uses an outdated Axios library, increasing exposure to known or future third-party vulnerabilities.
8. Sensitive API credentials are hardcoded in publicly accessible JavaScript files, allowing unauthorized access to backend APIs.
9. The login functionality reveals whether user accounts exist through distinct error messages, enabling attackers to enumerate valid users.
10. The web server hub.isendremit.com runs an outdated, end-of-life Nginx 1.22.1, exposing it to known security vulnerabilities.

3.3 Summary Of Recommendations

Envision Tech recommends the following suggestions to help maintain and improve iSend Web Applications current security level.

1. Implement X-Frame-Options and enforce a strict Content-Security-Policy (frame-ancestors) to prevent unauthorized framing.
2. Disable TLS 1.0 and TLS 1.1 and enforce TLS 1.2 or TLS 1.3 with strong cipher suites.
3. Disable autocomplete for sensitive input fields to prevent unintended data disclosure.
4. Implement a strict Content Security Policy to restrict trusted content sources and mitigate client-side attacks.
5. Upgrade Next.js to the latest supported version and clear server-side and CDN caches.
6. Implement a strict origin allowlist and avoid reflecting user-controlled origins with credentialed requests.
7. Update Axios to the latest stable version and regularly monitor dependency security advisories.
8. Remove credentials from client-side code, rotate exposed secrets, and move authentication logic to a secure backend.
9. Return a generic error message for all authentication failures to prevent disclosure of account existence.
10. Upgrade Nginx to the latest stable version to mitigate potential exploits.

4. DISCOVERED VULNERABILITIES

4.1 Clickjacking

Clickjacking		Risk	CVSSv3
Description	We observed that the official web application of iSend was vulnerable to clickjacking. The web application allowed attackers to hijack user’s clicks for malicious intent. In clickjacking, users are tricked into performing all sorts of unintended actions such as typing password, clicking on ‘Delete’ Buttons, editing posts and so on. In other words, all the actions that a normal user can do on a legitimate website can be done using clickjacking.		
Url	https://isend.com.np/		
Affected Url	https://isend.com.np/ , https://isendremit.com/ , https://isendbiz.com/ , https://isendglobal.com/		
Impact	Attackers can execute multiple attacks including keylogging, stealing user credentials and also manipulate the users to open malicious websites through social engineering methods to install malware or gain access to critical systems.		
Remediation	1. Implement X-Frame-Options HTTP header. • Use DENY to block all framing. • Use SAMEORIGIN if same-domain framing is required. 2. Enforce Content-Security-Policy using frame-ancestors.		
References	https://owasp.org/www-community/attacks/Clickjacking		
CVSSv3 Metrics			
Step of Reproduction/Proof of Concept (PoC):			

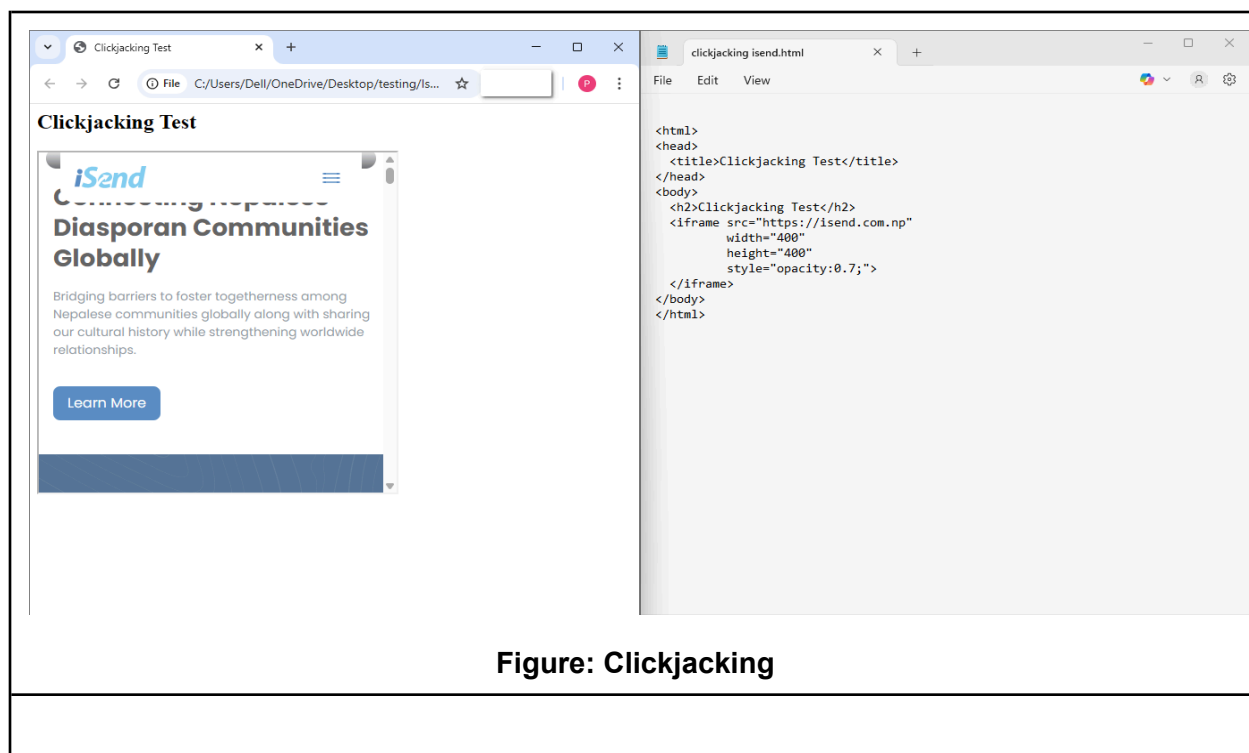


Figure: Clickjacking

4.2 TLS v1.0 and TLS v1.1 Depreciated Protocol Detection

TLS v1.0 and TLS v1.1 Depreciated Protocol Detection		Risk	CVSSv3
Description	The isend website supports the deprecated TLS v1.0 and TLS v1.1 protocols. These older versions of TLS are considered insecure and have been formally deprecated by the IETF (RFC 8996). They lack support for modern cryptographic algorithms and are vulnerable to various attacks, including protocol downgrade, weak cipher negotiation, and potential confidentiality compromise.Modern browsers and compliance frameworks (PCI-DSS, NIST 800-52r2, ISO 27001) require disabling these protocols and enforcing TLS v1.2 or TLS v1.3 for secure communication.		
Url	https://isend.com.np/		

Affected Url	https://isend.com.np/ , https://isendbiz.com/ , https://isendglobal.com/ ,
Impact	An attacker on the network could downgrade connections to deprecated TLS versions. This may weaken encryption and reduce the confidentiality of data in transit. Sensitive information, such as login credentials or personal data, could be exposed.
Remediation	1. Disable support for TLS 1.0 and TLS 1.1 in the web server's configuration. 2. Enable TLS 1.2 or TLS 1.3 with strong cipher suites (e.g., those using ECDHE and AES-GCM) to ensure secure connections. 3. Disable all CBC-mode encryption methods, which are vulnerable to certain attacks (BEAST, Lucky13).
References	https://developers.cloudflare.com/ssl/edge-certificates/additional-options/minimum-tls
CVSSv3 Metrics	

Step of Reproduction/Proof of Concept (PoC):

```

(subash@kali)-[~]
$ nmap --script ssl-enum-ciphers -p 443 isend.com.np
[sudo] password for subash:
Starting Nmap 7.98 ( https://nmap.org ) at 2025-12-31 23:51 -0500
Nmap scan report for isend.com.np (172.67.153.112)
Host is up (0.0039s latency).
Other addresses for isend.com.np (not scanned): 2606:4700:3036::ac43:9970 2606:4700:3031::6815:4a1a 104.21.74.26

PORT      STATE SERVICE
443/tcp   open  https
| ssl-enum-ciphers:
|   TLSv1.0:
|     ciphers:
|       TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
|       TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
|     compressors:
|       NULL
|     cipher preference: server
|   TLSv1.1:
|     ciphers:
|       TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
|       TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
|     compressors:
|       NULL
|     cipher preference: server
|   TLSv1.2:
|     ciphers:
|       TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
|       TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256 (ecdh_x25519) - A
|       TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|       TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A
|       TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384 (ecdh_x25519) - A
|       TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
|       TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
|     compressors:

```

Figure: TLS v1.0 and TLS v1.1

4.3 Autocomplete Attribute Not Disabled on Form Fields

Autocomplete Attribute Not Disabled on Form Fields		Risk	CVSSv3
Description	The form input fields on iSend.com.np lack the autocomplete attribute (or are not set to "off"), causing browsers to enable autocomplete by default. This allows caching and autofilling of entered values such as company name, website URL, contact person, and phone number. While this enhances user convenience, it creates a privacy risk: on shared, public, or compromised devices, an unauthorized user with browser access could retrieve these cached business contact details via autofill suggestions, without needing additional exploits.		
Url	https://isend.com.np/		
Affected Url	https://isend.com.np/partner-contact-us.html		
Impact	1. If a user's device is shared or compromised, previously entered data could be accessed by unauthorized parties via browser autofill, potentially exposing business contact details.		
Remediation	1. Add autocomplete="off" to the <form> tag or individual <input> tags for sensitive or non-reusable fields to prevent browsers from caching and autofilling values.		
References	- https://developer.mozilla.org/en-US/docs/Web/Security/Practical_implementation_guides/Turning_off_form_autocompletion		
CVSSv3 Metrics			

Step of Reproduction/Proof of Concept (PoC):

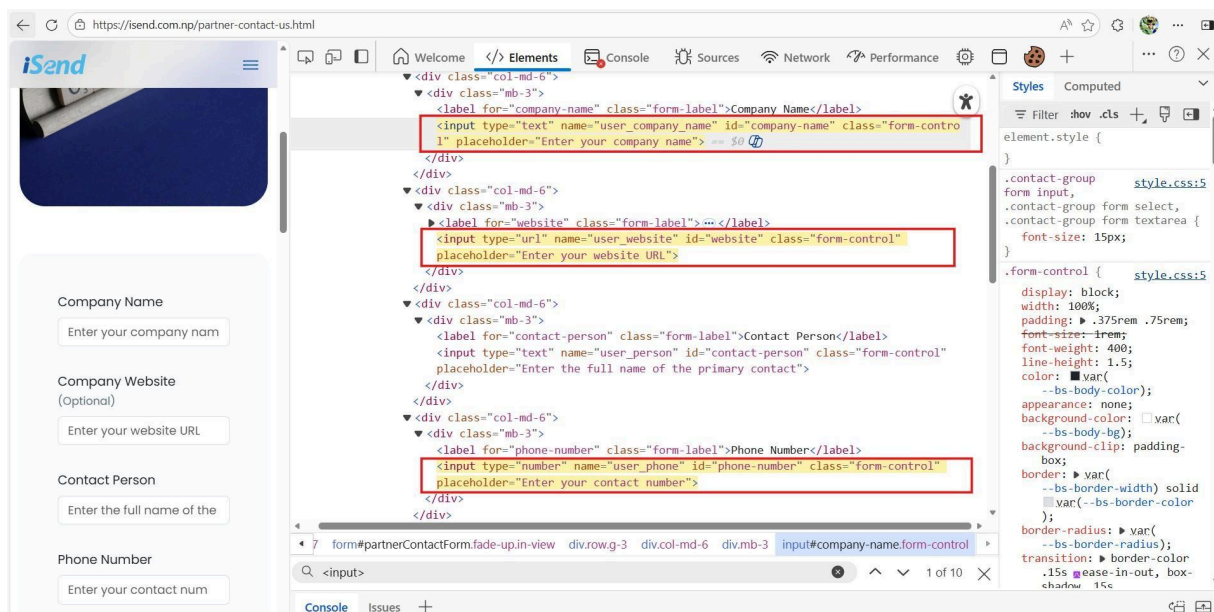


Figure: Autocomplete Attribute Not Disabled on Form Fields (Tabnabbing)

4.4 Missing Content Security Policy (CSP) Header

Missing Content Security Policy (CSP) Header		Risk	CVSSv3
Description	It was observed that the iSend website does not implement a Content Security Policy (CSP) header. CSP helps prevent client-side attacks by restricting the sources from which scripts and other resources can be loaded. Without CSP, browsers may execute malicious content from unauthorized sources.		
Url	https://isend.com.np/		
Affected Url	https://isend.com.np/ , https://isendbiz.com/ , https://isendglobal.com/ , https://isendremit.com/ https://hub.isendremit.com/login		

Impact	Without a CSP, the website is vulnerable to client-side attacks. If input validation flaws exist, attackers could inject malicious scripts to: 1. Steal session tokens or sensitive data. 2. Redirect users to phishing pages. 3. Manipulate or deface content
Remediation	Implement a strict Content Security Policy (CSP) header to restrict allowed sources of content. Example Configuration: Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'; base-uri 'self'; frame-ancestors 'none';
References	https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
CVSSv3 Metrics	

Step of Reproduction/Proof of Concept (PoC):

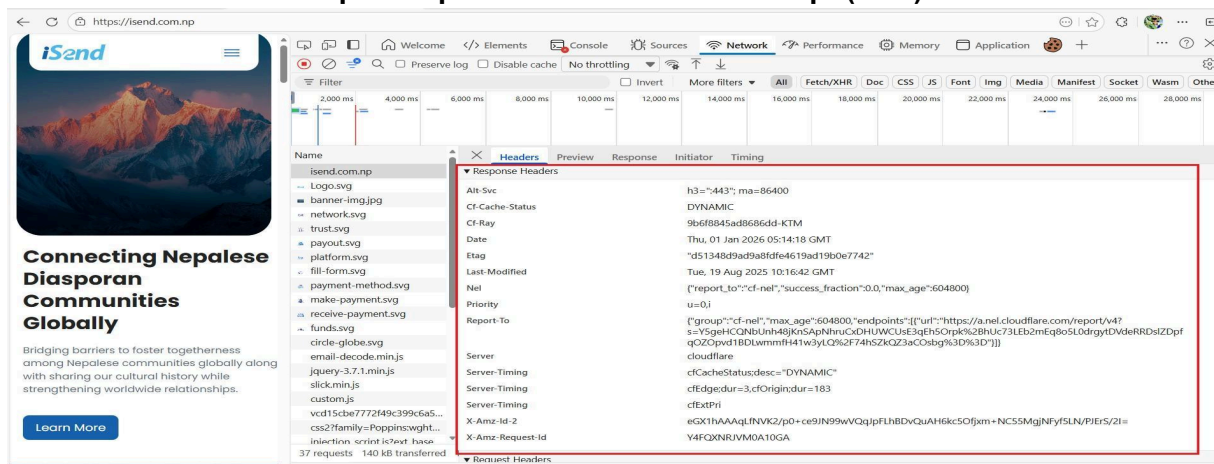


Figure: Missing Content Security Policy Header

4.5 Multiple Outdated (Next.js React Framework)

Multiple Outdated (Next.js React Framework)		Risk	CVSSv3
Description			
Multiple iSend web applications were found to be running outdated versions of the Next.js React framework, which were publicly detected through exposed JavaScript bundle files (_next/static/chunks/*.js). The detected versions are no longer the latest stable releases and may contain known security weaknesses. The following Next.js versions were identified during testing: • isendbiz.com is running Next.js version 13.5.4 • isendglobal.com is running Next.js version 13.4.19 • hub.isendremit.com is running Next.js version 14.0.3 These versions are several releases behind the current stable version and expose the applications to risks associated with vulnerable and outdated components. Additionally, the explicit disclosure of framework versions in client-side resources assists attackers during reconnaissance and technology fingerprinting.			
Url		https://www.isendbiz.com/	
Affected Url		https://www.isendbiz.com/_next/static/chunks/864-95fe18c5d214b152.js https://isendglobal.com/_next/static/chunks/596-d4cfd2bb84cad487.js https://hub.isendremit.com/_next/static/chunks/2472-0d21a6e8127c6a60.js	

Impact	1. Exposure to known and future vulnerabilities affecting outdated Next.js versions. 2. Increased attack surface due to unsupported or unpatched framework components. 3. Enables technology fingerprinting, assisting attackers in targeted attacks. 4. Potential exploitation of framework-level weaknesses depending on server configuration.
Remediation	1. Upgrade all affected applications to the latest stable and supported version of Next.js. 2. Establish a regular patch management process for frontend frameworks. 3. Monitor official Next.js security advisories. 4. Clear application and CDN caches after framework upgrades.
References	- https://nvd.nist.gov/vuln/detail/CVE-2024-46982 - https://nextjs.org/blog/security-update-2025-12-11
CVSSv3 Metrics	

Step of Reproduction/Proof of Concept (PoC):

```

(self.webpackChunk_N_E=self.webpackChunk_N_E||[]).push([[864],[2335:function(){String.prototype.trimStart=String.prototype.trimLeft,"trimEnd"in String.prototype||(String.prototype.trimEnd=String.prototype.trimRight),"description"in Symbol.prototype|Object.defineProperty(Symbol.prototype,"description",{configurable:!0,get:function(){var e=/((.*)\\).exec(this.toString());return e[1]:void 0}}),Array.prototype.flat||(Array.prototype.flat=function(e,t){return t=this.concat.apply([],this),e>1&&t.some(Array.isArray)?t.flat(e-1):t},Array.prototype.flatMap=function(e,t){return this.map(e,t).flat()},Promise.prototype.finally||(Promise.prototype.finally=function(e){if("function"!=typeof e)return this.then(e,e);var t=this.constructor||Promise;return this.then(function(r){return t.resolve(e()).then(function(){return r}}),function(r){return t.resolve(e()).then(function(){throw r}})}),Object.fromEntries||(Object.fromEntries=function(e){return Array.from(e).reduce(function(e,t){return e[t[0]]=t[1],e},{}),Array.prototype.at||(Array.prototype.at=function(e){var t=Math.trunc(e)||0;if(t<0&&(t+=this.length),!t<0|t>this.length)return this[t]}),9207:function(e,t,r){return "use strict";Object.defineProperty(t,"__esModule",{value:!0}),Object.defineProperty(t,"addBasePath",{enumerable:!0,get:function(){return addBasePath}});let n=r(6182),a=r(474);function addBasePath(e,t){return(0,a.normalizePathTrailingSlash)((0,n.addPathPrefix)(e,""))}{"function"==typeof t.default||"object"==typeof t.default&&null!==t.default&&void 0===t.default.__esModule&&Object.defineProperty(t.default,"__esModule",{value:!0}),Object.assign(t.default,t),e.exports=t.default},1160:function(e,t,r){return "use strict";function appBootstrap(e){var t,r;t=self.__next_s,r=(e)=>{e(),t&&t.length?t.reduce((e,t)=>{let[r,n]=t;return e.then(()=>new Promise((e,t)=>{let a=document.createElement("script");if(n)for(let e in n)"children"!=e&&a.setAttribute(e,n[e];r?(a.src=r,a.onload=()=>e(),a.onerror=t):n&&(a.innerHTML=n.children,setTimeout(e)),document.head.appendChild(a)}),Promise.resolve()).catch(e=>{console.error(e)}).then(()=>{r()}):r()}Object.defineProperty(t,"__esModule",{value:!0}),Object.defineProperty(t,"appBootstrap",{enumerable:!0,get:function(){return appBootstrap}}),window.next={version:"13.5.4",appDir:!0},{"function"==typeof t.default||"object"==typeof t.default&&null!==t.default&&void 0===t.default.__esModule&&Object.defineProperty(t.default,"__esModule",{value:!0}),Object.assign(t.default,t),e.exports=t.default},2655:function(e,t,r){return "use strict";Object.defineProperty(t,"__esModule",{value:!0}),Object.defineProperty(t,"callServer",{enumerable:!0,get:function(){return callServer}});let n=r(6054);async function callServer(e,t){let r=(0,n.getServerActionDispatcher)();if(!r)throw Error("Invariant: missing action dispatcher.");return new Promise((n,a)=>{r({actionId:e,actionArgs:t,resolve:n,reject:a})})}{"function"==typeof t.default||"object"==typeof

```

PoC: Outdated (Next.js React Framework) 13.5.4


```

(self.webpackChunk_N_E=self.webpackChunk_N_E||[]).push([[596],[2335:function(){"trimStart"in String.prototype||
(String.prototype.trimStart=String.prototype.trimLeft),"trimEnd"in String.prototype||
(String.prototype.trimEnd=String.prototype.trimRight),"description"in
Symbol.prototype||Object.defineProperty(Symbol.prototype,"description",{configurable:!0,get:function(){var e=/\
((.*)\\).exec(this.toString());return e[1]:void 0}}),Array.prototype.flat||(Array.prototype.flat=function(e,t){return
t=this.concat.apply([],this),e>1&&t.some(Array.isArray)?t.flat(e-1):t},Array.prototype.flatMap=function(e,t){return
this.map(e,t).flat()},Promise.prototype.finally||(Promise.prototype.finally=function(e){if("function"!=typeof e)return this.then(e,e);var
t=this.constructor||Promise;return this.then(function(r){return t.resolve(e()).then(function(){return r});function r(){return
t.resolve(e()).then(function(){throw r})}}),Object.fromEntries||(Object.fromEntries=function(e){return Array.from(e).reduce(function(e,t)
{return e[t[0]]=t[1],e,{})),6711:function(e,t,r){"use strict";Object.defineProperty(t,"__esModule",
{value:!0}),Object.defineProperty(t,"addBasePath",{enumerable:!0,get:function(){return o}});let n=r(7253),u=r(6070);function o(e,t)
{return(0,n.normalizePathTrailingSlash)((0,n.addPathPrefix)(e,""))})("function"==typeof t.default||"object"==typeof
t.default&&null!=t.default&&void 0===t.default.__esModule&&Object.defineProperty(t.default,"__esModule",
{value:!0}),Object.assign(t.default,t),e.exports=t.default}),4843:function(e,t,r){"use strict";function r(e){var t,r;t=self.__next_s,r=()=>
{e(),t&&t.length?t.reduce((e,t)=>{let[r,n]=t;return e.then(()=>new Promise((e,t)=>{let u=document.createElement("script");if(n)for(let e
in n)"children"!==e&&u.setAttribute(e,n[e]);r?u.src=r,u.onload=()=>e(u),u.onerror=t:n&&
(u.innerHTML=n.children,setTimeout(e)),document.head.appendChild(u)}),Promise.resolve().catch(e=>{console.error(e)})).then(()=>
{r()}):r()}Object.defineProperty(t,"__esModule",{value:!0}),Object.defineProperty(t,"appBootstrap",{enumerable:!0,get:function(){return
r}});window.next=(version:"13.4.19",appDir:!0),("function"==typeof t.default||"object"==typeof t.default&&null!=t.default&&void
0===t.default.__esModule&&Object.defineProperty(t.default,"__esModule",
{value:!0}),Object.assign(t.default,t),e.exports=t.default}),4039:function(e,t,r){"use strict";Object.defineProperty(t,"__esModule",
{value:!0}),Object.defineProperty(t,"callServer",{enumerable:!0,get:function(){return u}});let n=r(7948);async function u(e,t){let r=
(0,n.getServerActionDispatcher());if(!r)throw Error("Invariant: missing action dispatcher.");return new Promise((n,u)=>
{r({actionId:e,actionArgs:t,resolve:n,reject:u}))})("function"==typeof t.default||"object"==typeof t.default&&null!=t.default&&void
0===t.default.__esModule&&Object.defineProperty(t.default,"__esModule",

```

PoC: Outdated (Next.js React Framework) 13.4.19

```

(self.webpackChunk_N_E=self.webpackChunk_N_E||[]).push([[2472],[85844:function(e,t){"use strict";function r(){return""}Object.defineProperty(t,"__esModule",
{value:!0}),Object.defineProperty(t,"getDeploymentIdQueryOrEmptyString",{enumerable:!0,get:function(){return r}}),2335:function(){"trimStart"in String.prototype||
(String.prototype.trimStart=String.prototype.trimLeft),"trimEnd"in String.prototype||
(String.prototype.trimEnd=String.prototype.trimRight),"description"in
Symbol.prototype||Object.defineProperty(Symbol.prototype,"description",{configurable:!0,get:function(){var e=/\
((.*)\\).exec(this.toString());return e[1]:void
0}}),Array.prototype.flat||(Array.prototype.flat=function(e,t){return
t=this.concat.apply([],this),e>1&&t.some(Array.isArray)?t.flat(e-
1):t},Array.prototype.flatMap=function(e,t){return this.map(e,t).flat()},Promise.prototype.finally||(Promise.prototype.finally=function(e){if("function"!=typeof e)
return this.then(e,e);var t=this.constructor||Promise;return this.then(function(r){return t.resolve(e()).then(function(){return r});function r(){return
t.resolve(e()).then(function(){throw r})}}),Object.fromEntries||(Object.fromEntries=function(e){return Array.from(e).reduce(function(e,t){return e[t[0]]=t[1],e,
{})),Array.prototype.at||(Array.prototype.at=function(e){var t=Math.trunc(e)||0;if(t<0&&(t+=this.length),!(t<0||t>this.length))return
this[t]}),89872:function(e,t,r){"use strict";Object.defineProperty(t,"__esModule",{value:!0}),Object.defineProperty(t,"addBasePath",{enumerable:!0,get:function()
{return u}});let n=r(8356),o=r(43997);function u(e,t){return(0,o.normalizePathTrailingSlash)((0,n.addPathPrefix)(e,""))})("function"==typeof t.default||"object"==typeof
t.default&&null!=t.default&&void 0===t.default.__esModule&&Object.defineProperty(t.default,"__esModule",
{value:!0}),Object.assign(t.default,t),e.exports=t.default}),25354:function(e,t){"use strict";function r(e){var t,r;t=self.__next_s,r=()=>{e(),t&&t.length?
t.reduce((e,t)=>{let[r,n]=t;return e.then(()=>new Promise((e,t)=>{let o=document.createElement("script");if(n)for(let e in n)"children"!==e&&o.setAttribute(e,n[e]);r?
(o.src=r,o.onload=()=>e(o),o.onerror=t:n&&o.innerHTML=n.children,setTimeout(e)),Promise.resolve().catch(e=>{console.error(e)})).then(()=>{r()}):r()}Object.defineProperty(t,"__esModule",{value:!0}),Object.defineProperty(t,"appBootstrap",{enumerable:!0,get:function(){return
r}});window.next=(version:"14.0.3",appDir:!0),("function"==typeof t.default||"object"==typeof t.default&&null!=t.default&&void 0===t.default.__esModule&&
Object.defineProperty(t.default,"__esModule",
{value:!0}),Object.assign(t.default,t),e.exports=t.default}),15231:function(e,t,r){"use
strict";Object.defineProperty(t,"__esModule",{value:!0}),Object.defineProperty(t,"callServer",{enumerable:!0,get:function(){return o}});let n=r(33728);async function
o(e,t){let r=(0,n.getServerActionDispatcher());if(!r)throw Error("Invariant: missing action dispatcher.");return new Promise((n,o)=>
{r({actionId:e,actionArgs:t,resolve:n,reject:o}))})("function"==typeof t.default||"object"==typeof t.default&&null!=t.default&&void 0===t.default.__esModule&&
Object.defineProperty(t.default,"__esModule",{value:!0}),Object.assign(t.default,t),e.exports=t.default}),20811:function(e,t,r){"use strict";let

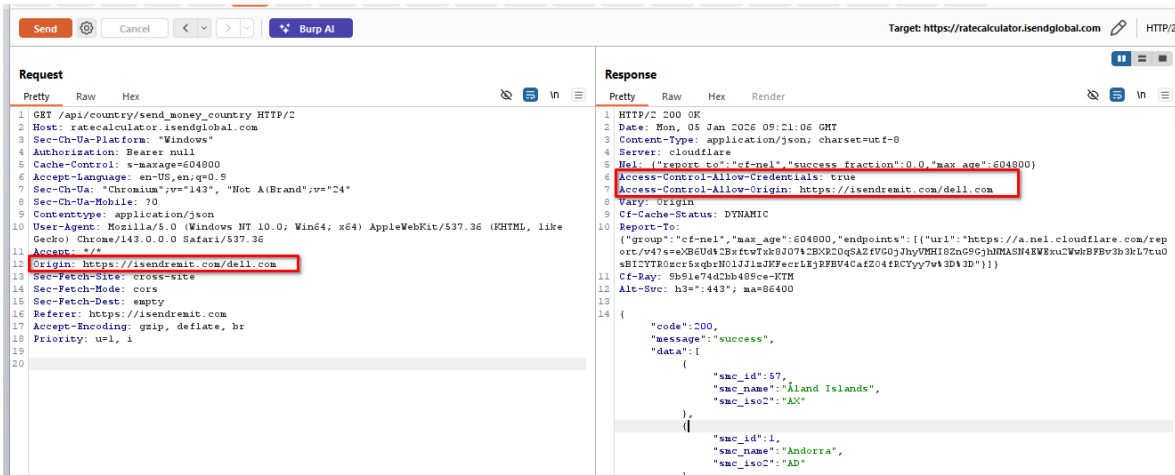
```

PoC: Outdated (Next.js React Framework) 14.0.3

4.6 CORS Misconfiguration

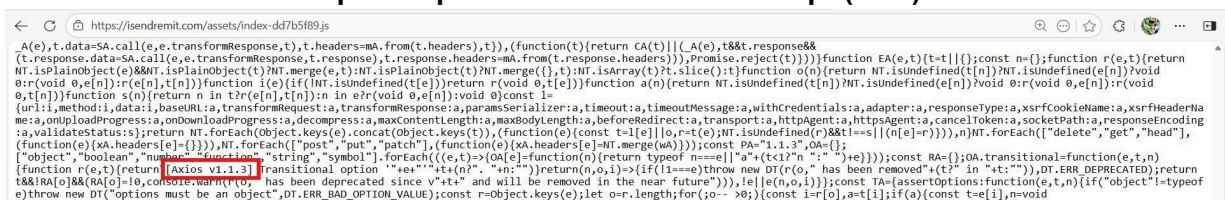
CORS Misconfigurations	Risk	CVSSv3

Description	We observed that the application's CORS policy is insecurely configured to trust arbitrary origins. The server reflects the Origin request header directly into the Access-Control-Allow-Origin response header and includes Access-Control-Allow-Credentials: true. The validation logic is flawed, as it accepts attacker-controlled origins (e.g., https://isendremit.com/dell.com). This allows a malicious site to perform authenticated requests using the victim's session cookies and exfiltrate sensitive response data.
Url	https://isendremit.com/
Affected Url	https://ratecalculator.isendglobal.com/api/country/send_money_country
Impact	An attacker can host a malicious script that makes authenticated requests to the API on behalf of a logged-in user. Because the CORS policy allows credentials and reflects arbitrary origins, the attacker can bypass the Same-Origin Policy (SOP) to steal sensitive user data, PII, or session-related information directly from the API responses.
Remediation	1. Remove dynamic reflection of the Origin header in Access-Control-Allow-Origin. 2. Implement a strict server-side allowlist of trusted origins with exact string matching. 3. Reject requests from untrusted origins before CORS headers are set. 4. Only enable Access-Control-Allow-Credentials: true for trusted origins and required endpoints. 5. Apply CORS headers conditionally per endpoint, not globally.

References	https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/11-Client-side_Testing/07-Testing_Cross-Origin_Resource_Sharing
CVSSv3 Metrics	
Step of Reproduction/Proof of Concept (PoC):  Figure: CORS Misconfiguration	

4.7 Use of vulnerable outdated components Axios v1.1.3

Outdated Axios v1.1.3		Risk	CVSSv3
Description	The website uses an outdated version of Axios (v1.1.3), a JavaScript library for handling HTTP requests. This version lacks security, stability, and robustness improvements introduced in newer releases. The use of outdated third-party components increases the application's attack surface and may expose it to known or future vulnerabilities, potentially leading to unintended request behavior or information disclosure when combined with insecure backend		

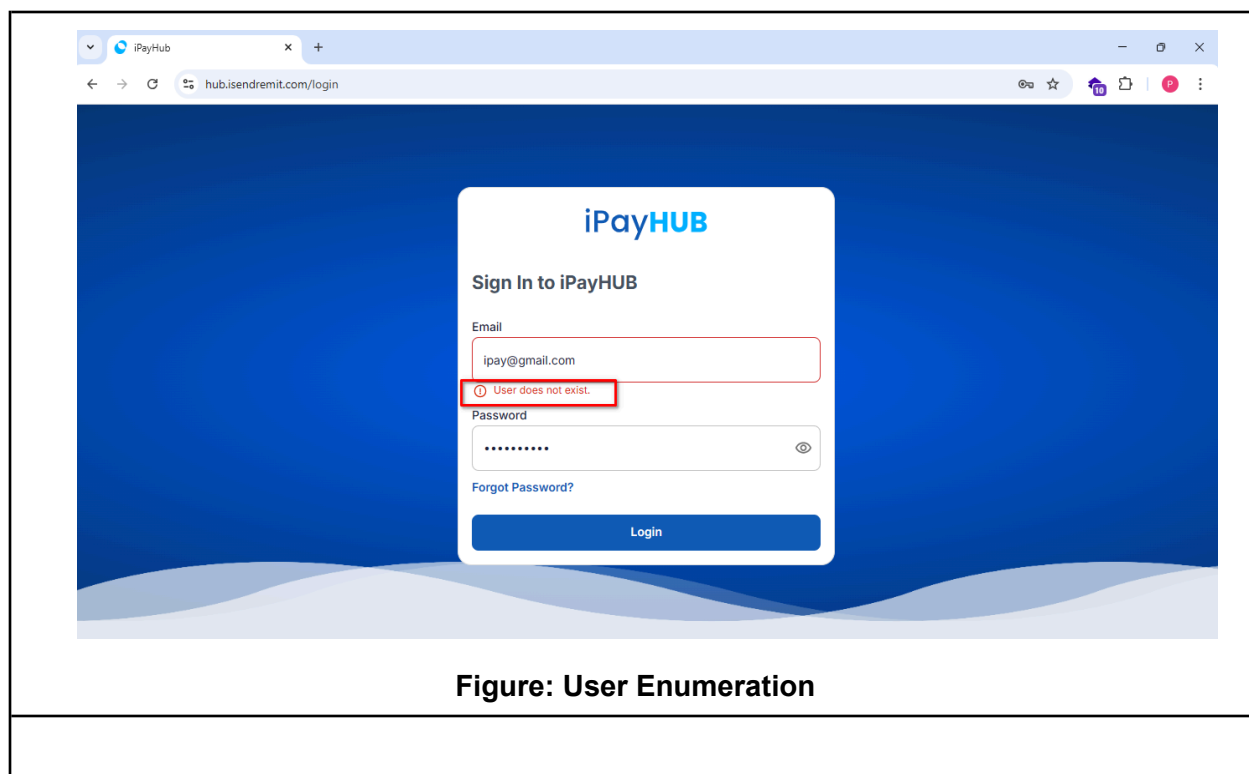
	configurations. This issue aligns with OWASP Top 10 (A06: Vulnerable and Outdated Components).
Url	https://isendremit.com/
Affected Url	https://isendremit.com/assets/index-dd7b5f89.js
Impact	- Increased exposure to known and future vulnerabilities affecting Axios. - Potential for information disclosure or request manipulation if combined with: Insecure backend API implementations. Improper input validation. Unsafe URL or redirect handling.
Remediation	Update Axios to the latest stable version.
References	https://owasp.org/Top10/2021/A06_2021-Vulnerable_and_Outdated_Components/index.html https://github.com/axios/axios/releases
CVSSv3 Metrics	
Step of Reproduction/Proof of Concept (PoC):  Figure: Outdated Axios v1.1.3	

4.8 API Credentials Exposed

	Risk	CVSSv3
--	------	--------

API Credential Exposed			
Description	The application exposes sensitive API credentials directly within a publicly accessible client-side JavaScript file. The file Landing-a573a060.js, served under the /assets/ directory, contains hardcoded authentication details including a username and password used to obtain an API token. Because client-side JavaScript is fully readable by any user, these credentials can be extracted by attackers through browser developer tools or by directly accessing the asset URL. This design violates secure credential management principles and significantly increases the risk of API abuse and data compromise.		
Url	https://isendremit.com/		
Affected Url	https://isendremit.com/assets/Landing-a573a060.js		
Impact	An attacker can: 1. Extract hardcoded API credentials from the JavaScript file. 2. Obtain valid API access tokens without authorization. 3. Perform unauthorized API requests. 4. Abuse backend services (rate calculation, country data, delivery options). 5. Automate data scraping or launch denial-of-service attacks.		
Remediation	1. Remove all hardcoded credentials from client-side JavaScript immediately. 2. Move authentication logic to a secure backend server. 3. Rotate and revoke all exposed credentials immediately. 4. Ensure sensitive API endpoints cannot be accessed directly from the client.		

Description	The iPayHUB login page (hub.isendremit.com/login) reveals whether a user account exists based on the login error message. For example, entering an invalid email like ipay@gmail.com returns: “User does not exist”. This allows an attacker to determine which email addresses are registered in the system, potentially aiding targeted attacks such as phishing, brute-force, or credential stuffing.		
Url	https://hub.isendremit.com/login		
Affected Url	https://hub.isendremit.com/login		
Impact	1. Attackers can enumerate valid user accounts. 2. Facilitates targeted phishing campaigns against valid accounts. 3. Makes credential stuffing and brute-force attacks easier. 4. Helps attackers in reconnaissance.		
Remediation	Return a generic error message for login failures. Example: "Invalid email or password"		
References	https://owasp.org/Top10/2021/A07_2021-Identification and Authentication Failures/index.html		
CVSSv3 Metrics			
Step of Reproduction/Proof of Concept (PoC):			

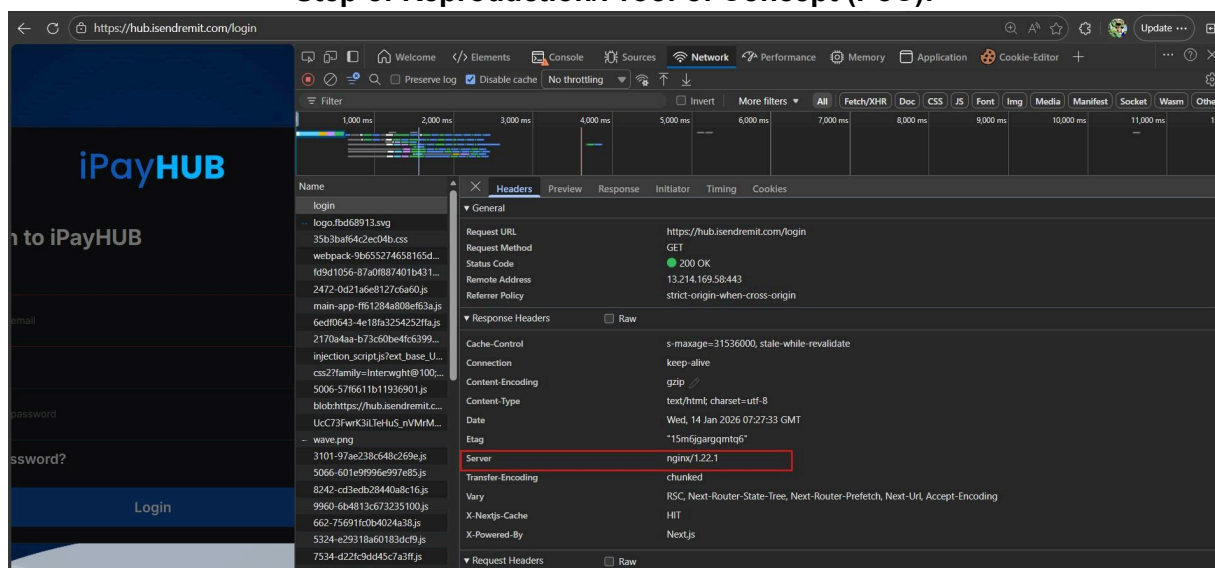


4.10 End-of-Life Nginx (1.22.1)

End-of-Life Nginx (1.22.1)		Risk	CVSSv3
Description	The web server (hub.isendremit.com) uses an EOL version of nginx (1.22.1), a popular open-source web server, reverse proxy, and load balancer. As of January 2026, the current stable branch is 1.28.1. Version 1.22.1 was released in late 2022 and is no longer actively maintained with security patches by the nginx project and is vulnerable to CVE-2025-23419, CVE-2025-53859		
Url	https://hub.isendremit.com/login		
Affected Url	https://hub.isendremit.com/login		

Impact	1. Attackers can exploit publicly disclosed vulnerabilities in the outdated Nginx version to potentially expose sensitive data from memory under certain conditions. 2. Attackers can reuse an SSL session from one site to bypass client certificate checks on another site sharing the same IP/port.
Remediation	Update Nginx to the latest stable version.
References	- https://eolstatus.com/product/nginx-inc-nginx-1-22 - https://stack.watch/product/nginx/nginx/
CVSSv3 Metrics	

Step of Reproduction/Proof of Concept (PoC):



PoC: EOL Nginx 1.22.1

5. CONCLUSION

During the period from 8 Aug 2025 to 7 Oct 2025, Envision Tech Pvt. Ltd. completed the Web Application Vulnerability Assessment and Penetration Testing for the client, Isend Pte. Ltd. During this assessment, a total of 10 different types of vulnerabilities were identified in the iSend Web Application.

Isend Pte. Ltd. must prioritize addressing the vulnerabilities outlined in this report by applying necessary patches and conducting thorough re-testing to confirm successful resolution of each issue. Envision Tech will collaborate with Isend Pte. Ltd. to verify the effectiveness of these fixes.

Given the frequent emergence of new zero-day vulnerabilities and the potential introduction of previously unknown threats through the implementation of new services, it is highly advised that Isend Pte. Ltd. conducts regular security assessments, occurring at least once every six months and not exceeding one year, to proactively identify and mitigate any potential vulnerabilities.

The current implementation of the recommendations contained in this report, along with continued diligence on the part of Isend Pty. Ltd., will result in the improvement of the security posture. It should be noted that the data in this report represents only a snapshot in time.

6. APPENDIX

A.1 CVSSv3 Risk Rating

Envision Tech captures the characteristics of vulnerabilities consistent with CVSSv3 (<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>) across the assessed environments. CVSSv3 provides a universal open and standardized method for rating IT vulnerabilities. CVSS helps organizations prioritize and coordinate a joint response to security vulnerabilities by communicating the properties of vulnerability. An overall risk rating of high, medium or low is then assigned based on the CVSSv3 score.

OWASP RISK METRICS	
N/A	INFORMATIONAL
0.1-3.9	LOW
4.0-6.9	MEDIUM
7.0-8.9	HIGH
9.0-10.0	CRITICAL

A.2 CWE (Common Weakness Enumeration)

Envision Tech captures the characteristics of software vulnerabilities consistent with CWE (<https://cwe.mitre.org>) of the assessed software. CWE provides a universal standardized method for describing software security weakness in architecture, design or code and provides a baseline for weakness identifications, mitigation and prevention efforts. CWE will often reference CVSSv3.1 vulnerability which provides consistent risk rating.

A.3 OWASP TOP 10

Envision Tech captures the characteristics of web application vulnerabilities as defined by the OWASP (Open Web Application Security Assessment Project) Top Ten categories (<https://www.owasp.org>). OWASP Top Ten is a list of the top ten most critical web application security vulnerabilities. The top ten vulnerabilities affecting your web

application are identified and assigned, allowing you to prioritize your remediation efforts. OWASP Top Ten will often reference CVSSv3 vulnerability information, which provides consistent risk reporting.

The following terms and ratings are used to describe each vulnerability that was found:

Target: Describes by name, which are affected by the named vulnerability.

Description: A detailed explanation of the vulnerability and possible consequences of its successful exploitation.

Remediation: Describes possible or suggested steps to take to resolve the vulnerability.

Reference: If additional outside information is available, such as that found on websites, it will be listed here.

Proof: Where applicable, additional detail or clarifying information is included.

Step of Reproduction/Proof of Concept (PoC): Where steps to reproduce the vulnerability are listed.

Black box testing: It is a testing strategy based solely on requirements and specifications. Black box testing requires no knowledge of internal paths, structures, or implementation of the software being tested.

White box testing: White box testing is a testing strategy based on internal paths, code structures, and implementation of the software being tested. This kind of testing generally requires detailed programming skills.

Gray box testing: This method mainly combines the advantages of the “white box” and “black box” methods. In this type of test, the tester knows the role of the system and its functionality and also knows (though not extensively) its internal mechanisms (especially the internal data structure and the algorithms used). However, he or she does not have access to the source code.

A.4 NIST SP 800-115

Envision Tech Pvt. Ltd. implements Technical Guide to Information Security Testing and Assessment while conducting VAPT. The NIST SP 800-115 guide provides practical recommendations for designing, implementing, and maintaining technical information

security test and examination processes and procedures. These can be used for several purposes, such as finding vulnerabilities in a web, system or network and verifying compliance with a policy or other requirements. It is an overview of key elements of technical security testing and examination, with an emphasis on specific technical techniques, the benefits and limitations of each, and recommendations for their use.

A.5 Tools Used

Nmap	Dirbuster
Nuclei	Nessus
Wappalyzer	Nikto
DNSrecon/DNSmap	Burp Suite Pro
Subfinder	OpenVas

–End of Report–

